

Atividade Plano de Segurança

Aluno: Felipe Roosevelt Duarte

Turma: B de Introdução à Computação

Plano de Segurança de Informação Hospitalar

1. O Cenário: Ambiente Hospitalar e suas Ameaças

O ecossistema de um hospital moderno é altamente digitalizado, composto por Prontuários Eletrônicos do Paciente (PEP), sistemas de triagem, comunicação médica e dispositivos médicos conectados à rede (IoMT).

Principais Ameaças Identificadas:

- **Ataques de Ransomware:** Sequestro de dados médicos com criptografia maliciosa, paralisando o atendimento emergencial e bloqueando o acesso a prontuários.
- **Vazamento de Dados Sensíveis (LGPD):** Exposição de diagnósticos, históricos e dados pessoais de pacientes por falha de configuração ou acessos não autorizados.
- **Interferência em Dispositivos IoMT:** Ataques direcionados a equipamentos médicos conectados (ex: bombas de infusão ou marca-passos), alterando dosagens ou comandos à distância.

2. O Arsenal: Mecanismos Tradicionais e Novas Tecnologias

Para blindar o sistema contra as ameaças acima, propõe-se uma estratégia de defesa em profundidade, dividida entre soluções consolidadas e inovações tecnológicas.

Mecanismos Tradicionais (A Base da Segurança):

- **Segmentação de Rede de Hardcore (VLANs):** Separar a rede administrativa, a rede de acesso de visitantes (Wi-Fi público), a rede do PEP e a rede exclusiva para os dispositivos médicos (IoMT). Se um computador de visitante for infectado, a infecção não se espalha para os aparelhos de suporte à vida.
- **Firewall de Nova Geração (NGFW) e VPN:** Bloqueio de tráfego suspeito na borda da rede e exigência de VPN segura com criptografia forte para qualquer acesso remoto de médicos aos prontuários.

- **Backups Criptografados e Isolados (3-2-1):** Três cópias dos dados, em dois tipos de mídia diferentes, com uma delas totalmente offline (Air-Gapped) para garantir a recuperação em caso de ataque por ransomware.

Novas Tecnologias (A Blindagem Avançada):

- **Arquitetura Zero Trust (Confiança Zero):** Implementação da filosofia de "nunca confiar, sempre verificar". Nenhum usuário ou dispositivo terá acesso automático a nada dentro do hospital, exigindo **Autenticação de Múltiplos Fatores (MFA)** biométrica a cada nova requisição.
- **EDR/XDR com Inteligência Artificial:** Monitoramento contínuo dos computadores e servidores do hospital. A IA identifica comportamentos anômalos (como um computador tentando ler 500 prontuários em um minuto) e isola a máquina automaticamente antes que um ransomware se espalhe.
- **Criptografia Homomórfica para Pesquisa Médica:** Permite que dados de saúde de pacientes sejam analisados e estatisticamente processados por IA ou pesquisadores parceiros sem a necessidade de descriptografar as informações de identificação pessoal, mantendo a conformidade absoluta com a LGPD.